

CONFIDENTIAL ACADEMIC SUBMISSION - CSE499 review and grading only.

Mercury Project

Threat Model

Assets, trust boundaries, threats, mitigations, residual risk, and out-of-scope items.

Course	CSE499 Senior Project
Author	Matthew D. Barker
Version	RC 1.2 (1.2.0-rc.1)
Date	July 2026
Use	Academic review and grading only

This document and related project materials may not be publicly posted, redistributed, showcased, or shared outside the course review process without prior written permission from the copyright owner.

Document Purpose

This document defines the threat model for Mercury RC 1.2. It identifies protected assets, trust boundaries, assumptions, attacker capabilities, threats, mitigations, residual risks, and intentionally out-of-scope concerns.

Security Position

Mercury assumes that transports may be untrusted. An attacker may observe, copy, modify, drop, delay, reorder, or replay frames. Mercury protects payloads before transport and releases plaintext only after structural validation, authenticated decryption, recipient validation, and replay protection succeed.

Mercury does not claim that a transport is secure. The transport is treated as a delivery mechanism for protected frames.

Assets

Asset	Protection Goal
Payload contents	Prevent unauthorized reading while the payload is protected or in transit.
Payload integrity	Detect modification before plaintext is released.
Authenticated envelope context	Protect version, envelope ID, timestamp, sender, recipient, algorithms, replay token, and metadata from undetected modification.
Replay-token uniqueness	Reject duplicate sender and replay-token combinations within the configured replay window.
SecureEnvelope structure	Decode and validate protected frames without trusting malformed lengths, fields, or unsupported versions.
Key selection context	Resolve the intended symmetric key by exact, case-sensitive KeyId.
Plaintext release point	Ensure plaintext reaches the application only after all required security checks succeed.
Framework availability	Limit avoidable memory growth in replay storage and supported transports while recognizing that full DoS resistance is out of scope.

Trust Boundaries

Boundary	Trust Position	Notes
Application to Mercury	Partially trusted	The application provides payloads and context. Mercury validates caller input and returns controlled failures where possible.
Mercury Core	Trusted component	Coordinates provider, codec, transport, replay protection, logging, and plaintext release decisions.
Crypto provider	Trusted plugin	Performs authenticated encryption, validates canonical envelope data, and releases plaintext only after authentication.
Envelope codec	Untrusted-input parser	Serializes and deserializes SecureEnvelope values. It provides structural validation but not cryptographic authentication.
Transport	Untrusted	Moves complete protected frames and provides no required confidentiality, integrity, authentication, or replay protection.
Key provider	Trusted assumption	Supplies key material by KeyId. Long-term provisioning, rotation, and secure storage remain outside RC 1.2.
Replay protector	Trusted component	Tracks accepted sender/token combinations using bounded process-local state.

Boundary	Trust Position	Notes
Demo UI and attack simulator	Demonstration only	Shows behavior and controlled attacks; it is not a production enforcement boundary.

Assumptions

1. The .NET AES-GCM and ChaCha20-Poly1305 implementations operate correctly.
2. Keys are generated with sufficient entropy, provisioned correctly, and protected outside Mercury.
3. Attackers do not possess valid secret key material.
4. The application checks receive success before using returned payload data.
5. Replay state remains available for the lifetime of the receiving context.
6. The operating system, .NET runtime, trusted process memory, and build environment are not compromised.
7. Mercury clients use consistent sender and recipient KeyId values.
8. The selected provider, codec, and transport are configured consistently on communicating endpoints.

Attacker Capabilities

- Observe protected frames in transit.
- Capture and replay previously valid protected frames.
- Modify ciphertext, authentication data, or encoded frame bytes.
- Modify authenticated header or footer fields while preserving a structurally valid envelope.
- Send malformed, truncated, oversized, or wrong-codec frames.
- Attempt decryption with incorrect keys or altered recipient identifiers.
- Drop, delay, duplicate, or reorder frames.
- Send many unique replay tokens to pressure replay storage.
- Attempt to trigger unsafe exception and failure paths.

Attacker Limitations

- Cannot break the selected authenticated-encryption algorithm.
- Cannot access valid secret key material.
- Cannot modify trusted application memory or Mercury code after deployment.
- Cannot compromise the operating system or .NET runtime.
- Cannot defeat every possible side-channel or traffic-analysis technique.

Threats and Mitigations

ID	Threat	Attack	Current Mitigation	Residual Risk
T-001	Eavesdropping	Attacker observes protected frames.	AES-GCM or ChaCha20-Poly1305 encrypts payload contents before transport.	Residual traffic size and timing information remain visible.
T-002	Protected-payload tampering	Attacker changes ciphertext, nonce, tag, or protected payload bytes.	Authenticated decryption fails and plaintext is not released.	Availability impact remains possible.
T-003	Envelope-context tampering	Attacker changes version, IDs, timestamp, algorithms, replay token, or metadata.	Canonical envelope data is supplied as authenticated data to completed providers.	Unsupported future fields require deliberate versioned design.
T-004	Replay	Attacker resends a previously accepted protected frame.	Replay protector records sender/token combinations and rejects duplicates.	Process restart clears in-memory history.

ID	Threat	Attack	Current Mitigation	Residual Risk
T-005	Wrong key	Receiver uses incorrect key material.	Authentication fails and plaintext remains empty.	Key provisioning errors still cause communication failure.
T-006	Malformed frame	Attacker sends invalid, truncated, or wrong-codec data.	Codec and receive paths return controlled decode failures without calling the provider when decoding fails.	Repeated malformed traffic may consume processing time.
T-007	Recipient confusion	Attacker redirects or alters recipient context.	Recipient KeyId is authenticated and the receiving client validates intended recipient identity.	Correct configuration of KeyId values remains required.
T-008	Transport compromise	Transport is observed, modified, or unreliable.	Security is applied above the transport; only protected frames are sent.	Transport-level availability is not guaranteed.
T-009	Replay-cache pressure	Attacker submits many unique valid envelopes.	Entries expire; active replay records are bounded; capacity failure is closed.	A full cache can reject legitimate new traffic until capacity returns.
T-010	Oversized frame pressure	Attacker declares or sends an excessive frame.	TCP and in-memory transports enforce maximum frame sizes.	Full system-wide rate limiting remains outside RC 1.2.
T-011	Unsafe failure	Invalid input triggers uncontrolled behavior or data release.	FailureReason results, cancellation behavior, and payload-empty assertions are covered by automated tests.	Unhandled host-level failures remain a deployment concern.
T-012	Weak or missing key identifiers	Invalid identifiers select no key or ambiguous state.	KeyId and AlgorithmId handle default values consistently; dictionary providers reject empty key identifiers and missing keys.	Production key lifecycle remains external.

STRIDE Review

STRIDE Category	Applicability	Current Control
Spoofing	Possible without a full identity system.	Authenticated encryption, exact key identifiers, intended-recipient validation, and authenticated context. Human or certificate identity is out of scope.
Tampering	Primary threat.	AEAD authentication covers payload and canonical envelope data; malformed frames fail before plaintext release.
Repudiation	Limited scope.	No audit-grade nonrepudiation. Digital signatures and durable audit storage are future work.
Information Disclosure	Primary threat.	Payload encryption and no-plaintext-on-failure behavior.
Denial of Service	Partially addressed.	Frame-size guards and bounded replay storage reduce avoidable resource growth. Full DoS resistance and rate limiting are out of scope.
Elevation of Privilege	Not directly modeled.	Mercury has no user-account or privilege-management model in RC 1.2.

Out-of-Scope Threats

- Operating system, runtime, trusted process, or developer-machine compromise.
- Memory scraping by malware and advanced side-channel attacks.
- Traffic analysis and endpoint fingerprinting.
- Public key infrastructure and certificate authority attacks.
- Hardware security module integration.
- Long-term production key rotation and key-exchange failures.
- Formal cryptographic verification and post-quantum cryptography.
- Production deployment certification, government certification, and regulatory compliance.
- Comprehensive distributed denial-of-service resistance.

Residual Risks

Risk	Reason	Recommended Future Work
Replay state lifetime	In-memory replay state is lost when the process restarts.	Provide persistent or distributed replay storage where deployment requirements justify it.
Identity proofing	Shared-key context does not prove a human or certificate-backed identity.	Add digital signatures or certificate-backed identity.
Key lifecycle	Mercury assumes key provisioning, storage, rotation, and revocation are solved externally.	Integrate secure key storage, rotation, and exchange mechanisms.
Availability	Attackers may flood transports, fill replay capacity, or repeatedly send malformed frames.	Add rate limiting, quotas, connection authentication, backpressure, and deployment-specific monitoring.
FileDrop operational recovery	File-based delivery has more filesystem and state-claim concerns than the primary in-memory and TCP paths.	Complete additional recovery, cleanup, path, and resource controls before production use.
AES-CCM status	The provider and its two tests remain pending.	Complete implementation, contract tests, pipeline tests, and demo verification before claiming support.
Side-channel exposure	Managed memory and platform behavior are not formally hardened against all observation techniques.	Evaluate zeroing, disposal, HSM integration, and deployment isolation for production scenarios.

Threat Model Conclusion

Mercury RC 1.2 appropriately demonstrates confidentiality, integrity, authenticated envelope context, replay rejection, wrong-key failure, safe failure, transport independence, and bounded in-memory replay state for the academic scope. It does not claim PKI, human identity proofing, production key lifecycle management, full denial-of-service resistance, side-channel certification, or government certification.